

ACTIVIDAD 04 – Una página demasiado convincente

Materia: CNO IV WAP

Alumno: Gasca López Santiago Isaac - 184730

Docente: Mtro. Servando López Contreras



Contenido

Objetivo de la Actividad	3
Descripción del escenario.....	3
Configuración del laboratorio	3
Evidencias	4
Simulación	7
Flujo de captura de información	8
Control de seguridad propuestos.....	9
Conclusión	9
Referencias	9

Objetivo de la Actividad

Simular un ataque de ingeniería social mediante Social-Engineer Toolkit (SET) en un entorno de laboratorio aislado, evaluando la interacción con un formulario web ficticio para analizar el comportamiento del protocolo y determinar los principales vectores de riesgo asociados al phishing.

Descripción del escenario

Una organización ficticia recibe reportes de empleados sobre un mensaje relacionado con la actualización de credenciales. El enlace conduce a un supuesto portal institucional. La página presenta usuario, contraseña y un mensaje de expiración de sesión.

Nuestro escenario concreto: sustituimos la institución real por GameWorld, un portal ficticio de videojuegos.

Configuración del laboratorio

Sistema operativo: Kali Linux

Direccionamiento IP: 10.0.2.15

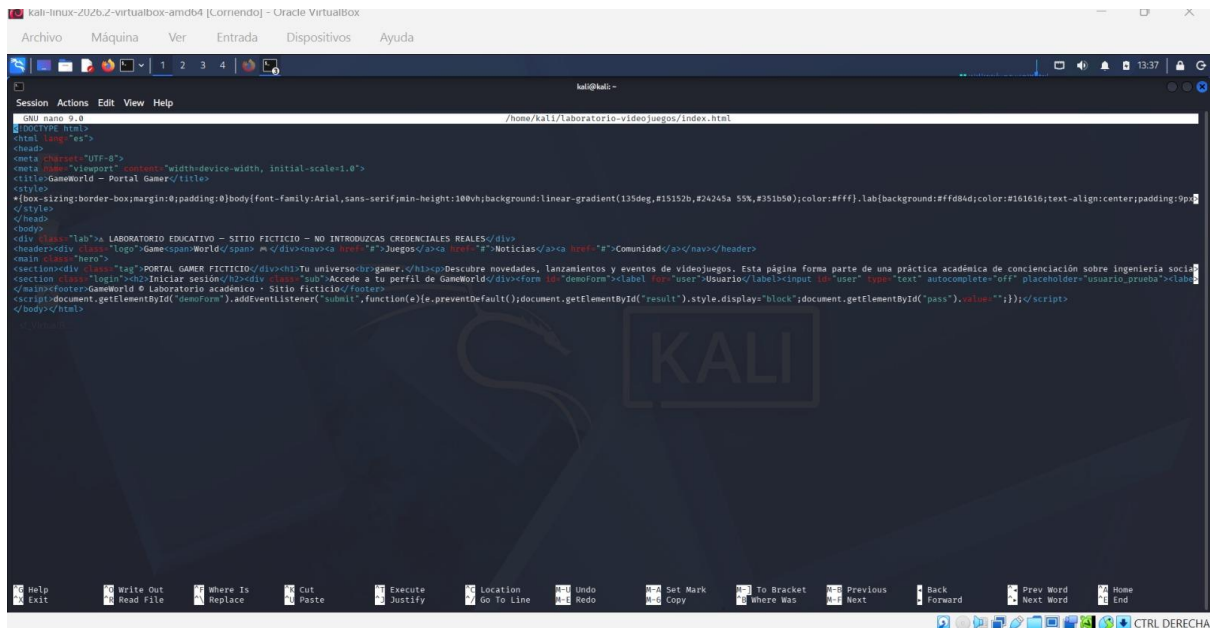
Herramientas: SET, Firefox

Website Attack Vectors

Credential Harvester

Sitio ficticio: GameWorld

1. Creación de nuestro index.html



2. Acceder al setoolkit

Con la terminal de Kali Linux accedemos para realizar las pruebas de penetración enfocadas en ingeniería social.



3. Configuración del ataque

Seleccionamos la opción 1)

```
Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set> 
```

4. Luego seleccionamos la opción 2) Website Attack Vector para posteriormente seleccionar la opción 3) Credential Harvester Attack Method

```
Session Actions Edit View Help
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 2

The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.

The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.

The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.

The Credential Harvester method will utilize web cloning of a website that has a username and password field and harvest all the information posted to the website.

The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.

The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based PowerShell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack> 
```

5. Finalmente se selecciona la opción 3) Custom Import

```
set:webattack>3

The first method will allow SET to import a list of pre-defined web
applications that it can utilize within the attack.

The second method will completely clone a website of your choosing
and allow you to utilize the attack vectors within the completely
same web application you were attempting to clone.

The third method allows you to import your own website, note that you
should only have an index.html when using the import website
functionality.

1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu
```

6. Se muestra nuestra IP

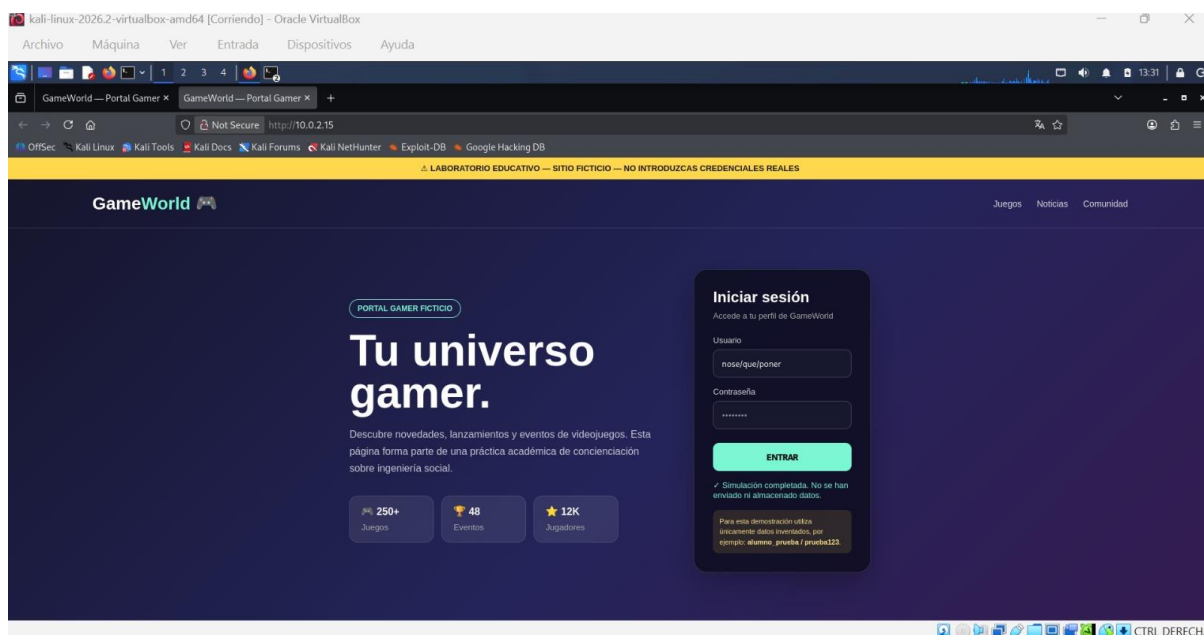
```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/laboratorio-videojuegos/
[*] Index.html found. Do you want to copy the entire folder or just index.html?

1. Copy just the index.html
2. Copy the entire folder

Enter choice [1/2]: 1
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://10.0.2.15

The best way to use this attack is if username and password form fields are available
in POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

Simulación

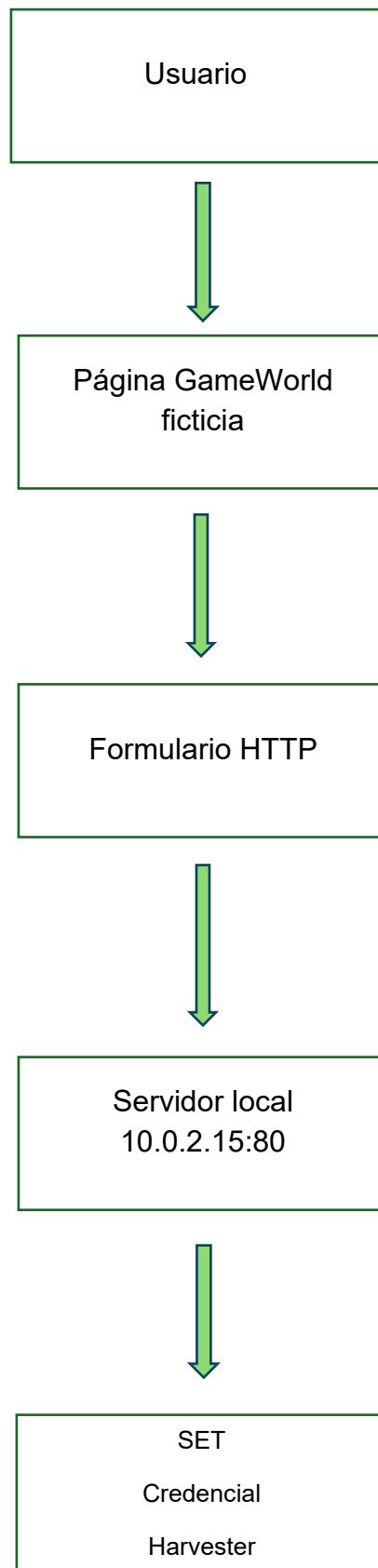


En la terminal donde se ejecuta SET se muestra en tiempo real las capturas de datos

```
Enter choice [1/2]: 1
[~] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://10.0.2.15

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
10.0.2.15 - - [31/Aug/2026 13:31:02] "GET / HTTP/1.1" 200 -
10.0.2.15 - - [31/Aug/2026 13:31:02] "GET /favicon.ico HTTP/1.1" 404 -
```

Flujo de captura de información



Control de seguridad propuestos

1. Verificar la URL y el dominio antes de introducir credenciales
2. Utilizar MFA: el uso de llaves físicas de seguridad o biométricas, inmuniza contra portales clonados, ya que la llave valida el nombre de dominio legítimo antes de firmar, su limitación es que requiere inversión en hardware y enrolamiento de usuarios.
3. Usar gestores de contraseñas, que ayudan a detectar dominios incorrectos.
4. Capacitar periódicamente a los usuarios para reconocer ingeniería social.
5. No acceder a enlaces de actualización de contraseña desde correos sospechosos.

Conclusión

Con esta actividad pudimos comprobar de una manera práctica que una página web puede parecer completamente normal y aun así representar un riesgo para la seguridad de los usuarios. Al crear una página ficticia de videojuegos y utilizarla dentro de un entorno controlado con Kali Linux y SET, fue posible observar cómo una página aparentemente sencilla puede formar parte de un escenario de ingeniería social.

Esto ayuda a entender que el phishing no depende únicamente de que una página tenga un diseño extraño, sino también de qué tan fácil es para una persona confiar en ella sin verificar su origen.

Referencias

Cybersecurity and Infrastructure Security Agency. (s. f.). *Recognize and report phishing*. U.S. Department of Homeland Security.

<https://www.cisa.gov/secure-our-world/recognize-and-report-phishing>

Merritt, M., Hansche, S., Ellis, B., Nethery Snyder, J., Sanchez-Cherry, K., & Walden, D. (2024). *Building a cybersecurity and privacy learning program* (NIST Special Publication 800-50 Rev. 1). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-50r1>

Kennedy, D. (s. f.). *SET user manual*. TrustedSec. [SET User Manual](#)